

Clase 291 — Introducción a la seguridad de IA y ML

Parte: **15 — Seguridad de IA y machine learning** · Fuente: *NIST AI RMF 1.0 (NIST AI 100-1)* y *MITRE ATLAS* 🕒 Duración estimada: **90 min** · Nivel: **Fundamentos**

🎯 Objetivo

Construir el mapa mental de la seguridad de la IA: entender por qué un sistema de machine learning tiene una superficie de ataque propia, distinta de la del software tradicional, y aprender a describir esa superficie con marcos estándar (MITRE ATLAS y NIST AI RMF). Al terminar, el alumno sabrá situar cualquier amenaza de las clases siguientes dentro del ciclo de vida datos → entrenamiento → modelo → despliegue → inferencia.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

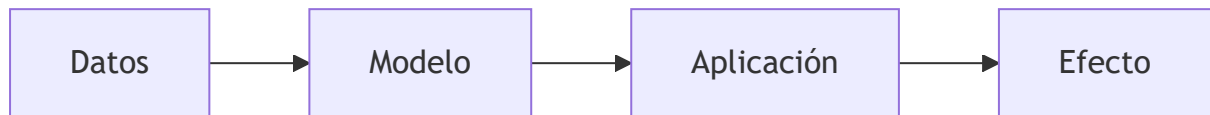
- 1. **Distinguir** las propiedades de seguridad de un modelo (confidencialidad, integridad, disponibilidad) de las del software clásico.
- 2. **Mapear** una amenaza concreta a una táctica y técnica de MITRE ATLAS.
- 3. **Clasificar** ataques según la fase del ciclo de vida y el conocimiento del atacante (caja blanca/negra).
- 4. **Relacionar** las funciones del NIST AI RMF (Govern, Map, Measure, Manage) con controles de seguridad.
- 5. **Construir** un modelo de amenazas inicial para un sistema de ML dado.

📖 Temas

#	Tema	Por qué importa
1	La tríada CIA aplicada a modelos	Redefine qué significa "seguro" para un modelo
2	Ciclo de vida del ML como superficie de ataque	Cada fase (datos, train, deploy, inferencia) es atacable
3	Taxonomía de atacantes: caja blanca vs. negra	Determina qué ataques son viables
4	MITRE ATLAS: tácticas y técnicas	Lenguaje común para amenazas de IA
5	NIST AI RMF: Govern/Map/Measure/Manage	Cómo se gobierna el riesgo de IA
6	AI Bill of Materials (AI-BOM) y cadena de suministro	Modelos y datos de terceros heredan riesgo
7	Diferencia entre seguridad, robustez y safety	Evita confundir problemas distintos

Explicación en profundidad

El riesgo de IA abarca datos, modelo, aplicación, infraestructura, usuarios y efectos. Seguridad del modelo y uso seguro no son equivalentes: un modelo robusto puede revelar datos por una integración deficiente, y una aplicación controlada puede depender de un modelo frágil.



El diagrama debe leerse como una cadena de supuestos: verificar un nodo no demuestra los siguientes. La evaluación declara actor, acceso, datos, métrica, umbral y consecuencia; compara una línea base y conserva fallos, no solo promedios.

Caso razonado

Un clasificador preciso falla sobre un grupo no representado. El equipo separa error de calidad, abuso deliberado e impacto de negocio antes de elegir control.



Glosario operativo

Término	Definición
Activo de IA	Componente o resultado cuyo daño importa.
Evaluación	Experimento reproducible ligado a un riesgo y criterio.
Riesgo residual	Exposición que permanece tras controles.



Criterio de dominio

El alumno demuestra dominio cuando formula un escenario específico, reproduce evidencia, explica límites y diseña controles técnicos y de gobierno sin atribuir certeza al modelo.



Definiciones y características

- **Superficie de ataque de IA:** conjunto de puntos donde un adversario puede influir en datos, entrenamiento, modelo o inferencia. *Característica:* se extiende a la cadena de suministro (datasets y modelos preentrenados de terceros).
- **Ataque de caja blanca:** el atacante conoce arquitectura, pesos y gradientes. *Característica:* permite ataques óptimos (p. ej. basados en gradiente) y sirve como peor caso en la evaluación.
- **Ataque de caja negra:** solo hay acceso a entradas/salidas (la API). *Característica:* usa consultas repetidas, transferibilidad o modelos sustitutos.
- **MITRE ATLAS:** base de conocimiento de tácticas (Reconnaissance, Resource Development, Initial Access, ML Model Access, Exfiltration, Impact...) y técnicas contra sistemas de IA, homóloga de ATT&CK.
- **NIST AI RMF:** marco voluntario con cuatro funciones —*Govern, Map, Measure, Manage*— para gestionar riesgos de IA a lo largo del ciclo de vida.

- **AI-BOM:** inventario de datos, modelos, dependencias y procedencia de un sistema de IA; base para gestionar riesgo de cadena de suministro.
- **Robustez vs. seguridad:** robustez es resistir perturbaciones (adversariales o no); seguridad es resistir a un adversario con intención. No son sinónimos.

Herramientas y preparación

Trabajaremos en un **laboratorio aislado** (VM o contenedor) sin datos reales de producción.

```
python -m venv .venv && source .venv/bin/activate # Windows: .venv\Scripts\activate
pip install adversarial-robustness-toolbox torch torchvision scikit-learn numpy
```

- **MITRE ATLAS Navigator** (web) para explorar la matriz: <https://atlas.mitre.org/>
- **NIST AI RMF Playbook** para consultar acciones sugeridas por función.
- Un modelo de juguete (por ejemplo un clasificador sobre MNIST o CIFAR-10) que usaremos en clases siguientes.

Laboratorio guiado

Este laboratorio es de **modelado**, no de explotación; aún así, cualquier prueba se hace sobre modelos y datos propios.

1. **Elige un sistema de referencia.** Toma un caso realista, p. ej. "API de scoring de crédito basada en un modelo de scikit-learn" o "chatbot de soporte con un LLM". Descríbelo en una frase.
2. **Dibuja el ciclo de vida.** En un diagrama, enumera las cinco fases: recolección de datos, entrenamiento, empaquetado del modelo, despliegue (API), inferencia. Para cada una, anota una entrada de datos y un actor con acceso.
3. **Enumera activos y propiedades CIA.** Por cada activo (dataset, pesos del modelo, API, prompts del sistema) marca qué te importa: confidencialidad (¿se puede robar el modelo?), integridad (¿se puede sesgar?), disponibilidad (¿se puede degradar con entradas costosas?).
4. **Mapea a MITRE ATLAS.** Abre el Navigator y localiza técnicas aplicables: por ejemplo "*Evade ML Model*", "*Poison Training Data*", "*Exfiltrate via ML Inference API*". Anota los IDs.
5. **Clasifica al atacante.** Para cada amenaza, decide si requiere caja blanca o negra y qué nivel de acceso (usuario de la API, insider del pipeline, proveedor del dataset).
6. **Cruza con NIST AI RMF.** Asigna cada riesgo a una función: *Map* (identificar contexto), *Measure* (métrica de robustez), *Manage* (control/mitigación), *Govern* (política/rol responsable).
7. **Prioriza.** Ordena las amenazas por (probabilidad × impacto) y marca las tres primeras como foco de las próximas clases.

Ejercicios

1. Para un filtro de spam, lista tres ataques distintos y ubícalos en el ciclo de vida.
2. Explica con un ejemplo por qué la transferibilidad hace peligrosos los ataques de caja negra.
3. Localiza en ATLAS un caso de estudio real (case study) y resume su cadena de ataque en 4 pasos.

- 4. Redacta, para el caso "chatbot con LLM", una entrada de riesgo con las cuatro funciones del AI RMF cubiertas.
- 5. Construye un AI-BOM mínimo (5 filas) para un modelo que usa un dataset público y un modelo preentrenado de Hugging Face.
- 6. Diferencia con ejemplos "robustez", "seguridad" y "safety" para un coche autónomo.

 Reto verificable

Entrega un **modelo de amenazas de una página** para un sistema de ML a tu elección que incluya: diagrama del ciclo de vida, tabla de activos con propiedades CIA, al menos 6 amenazas mapeadas a técnicas ATLAS (con ID), clasificación caja blanca/negra por amenaza y priorización top-3.

Criterio de aceptación: cada una de las 6 amenazas tiene (a) un ID ATLAS válido, (b) la fase del ciclo de vida afectada, (c) el tipo de atacante y (d) una función del NIST AI RMF asociada. Un revisor debe poder, leyendo solo tu tabla, entender qué defenderás primero y por qué.

 Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Mi modelo es seguro porque tiene buena accuracy"	Accuracy ≠ robustez. Mide desempeño bajo ataque, no solo en test limpio.
Tratar la IA como software normal en el threat model	Faltan datos y entrenamiento como activos. Modela el ciclo de vida completo, no solo la API.
Ignorar la cadena de suministro	Datasets/modelos de terceros heredan puertas traseras. Añade un AI-BOM.
Confundir caja blanca y negra	Suponer acceso a gradientes que no existe. Define primero el nivel de acceso del atacante.
Usar solo un marco	ATLAS describe amenazas; NIST AI RMF gestiona riesgo. Se complementan, no compiten.

 Preguntas frecuentes

-  **¿En qué se diferencia la seguridad de IA de la seguridad de software tradicional?** Añade dos activos nuevos —los datos de entrenamiento y el modelo aprendido— y ataques que explotan el comportamiento estadístico del modelo, no bugs de código. El pipeline de datos pasa a ser código de facto.
-  **¿MITRE ATLAS reemplaza a ATT&CK?** No. ATLAS es un complemento centrado en sistemas de IA; muchas cadenas reales combinan técnicas de ATT&CK (acceso inicial) con técnicas de ATLAS (evasión o envenenamiento del modelo).
-  **¿Necesito ser experto en ML para hacer seguridad de IA?** Ayuda, pero no es imprescindible al inicio. Muchos ataques a LLM son de caja negra y se parecen a AppSec. Los ataques adversariales sí requieren entender gradientes y entrenamiento.

? ¿El NIST AI RMF es obligatorio? Es voluntario, pero se está convirtiendo en referencia de facto y en base de requisitos regulatorios (p. ej. el AI Act europeo lo complementa). Adoptarlo facilita el cumplimiento futuro.

Referencias

- NIST AI Risk Management Framework 1.0 — <https://www.nist.gov/itl/ai-risk-management-framework>
- MITRE ATLAS — <https://atlas.mitre.org/>
- Biggio & Roli, "Wild Patterns", Pattern Recognition (2018).
- OWASP Machine Learning Security Top 10 — <https://owasp.org/www-project-machine-learning-security-top-10/>
- ENISA, "Securing Machine Learning Algorithms" (2021) — <https://www.enisa.europa.eu/>

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 290 — Certificaciones y desarrollo de carrera](#)

Siguiente clase

[Clase 292 — Ataques adversariales a modelos](#)